

KDLS 24 UG – Prüfungsvorbereitung AP1

Informationssicherheit – Wichtige Abkürzungen

1. CIA – Haupt-Schutzziele der Informationssicherheit

C – Confidentiality (Vertraulichkeit)

- Nur berechtigte Personen dürfen Informationen lesen oder nutzen.
- Maßnahmen: Verschlüsselung, Zugriffskontrolle, Rollenmodelle.

I – Integrity (Integrität)

- Informationen müssen korrekt und unverändert bleiben.
- Maßnahmen: Hashes, Prüfsummen, Änderungsprotokolle.

A – Availability (Verfügbarkeit)

- Informationen und Systeme müssen nutzbar sein, wenn sie gebraucht werden.
- Maßnahmen: Backups, Redundanz, Notfallkonzepte.

2. AAA – Authentication, Authorization, Accounting

- **Authentication:** Identitätsprüfung (Login, MFA).
- **Authorization:** Berechtigungen und Rollen.
- **Accounting:** Protokollierung von Aktivitäten.

3. DAD – Bedrohungsarten (Gegenstück zu CIA)

- **Disclosure:** Offenlegung → Angriff auf Vertraulichkeit.
- **Alteration:** Veränderung → Angriff auf Integrität.
- **Denial:** Verweigerung → Angriff auf Verfügbarkeit.

4. PDCA – Management-Zyklus

- **Plan:** Risiken analysieren, Maßnahmen planen.
- **Do:** Maßnahmen umsetzen.
- **Check:** Wirksamkeit prüfen.

- **Act:** Optimieren und nachsteuern.

5. ISMS – Information Security Management System

- Strukturiertes System zur Steuerung von Informationssicherheit.
- Kommt im BSI-Grundschutz und ISO 27001 vor.

6. TOM – Technische und organisatorische Maßnahmen (DSGVO)

- Zugriffskontrolle, Verschlüsselung, Pseudonymisierung.
- Backup, Monitoring, Schulungen.
- Bezug: Art. 32 DSGVO.

7. AVV – Auftragsverarbeitungsvertrag

- Regelt die Zusammenarbeit zwischen Verantwortlichem und Auftragsverarbeiter.
- Pflicht, wenn externe Dienstleister personenbezogene Daten verarbeiten.

8. DPIA – Data Protection Impact Assessment (DSGVO) Datenschutz-Folgenabschätzung

- Pflicht bei besonders riskanten Verarbeitungen.
- Beispiele: Videoüberwachung, große Datenmengen, Profiling.